

Prague University of Economics and Business
Faculty of Informatics and Statistics



**A Data Integration Framework
for Enterprise Application Security**

MASTER'S THESIS

Study program: Applied Data Analytics and Artificial Intelligence

Specialization: Retail and E-Commerce Data Analytics

Author: Bc. Vojtěch Kraus

Supervisor: Ing. Aleš Kotuč

Prague, month YYYY

Acknowledgements

I would like to thank Ing. Aleš Kotuč for his guidance and valuable feedback.

Abstract

To protect their business-critical applications from cybersecurity threats, enterprise security teams rely on numerous tools to detect and resolve vulnerabilities in application source code, configuration, dependencies, CI/CD pipelines, and runtime infrastructure. These tools use different integration patterns, protocols, and data formats, making it difficult to consistently parse, deduplicate, triage, and group their findings. In large environments, additional challenges emerge when linking all findings to the corresponding business applications. This thesis presents a data framework to tackle those challenges, delivering three distinct contributions: (1) a requirements specification for an application security data platform, (2) a reusable and extensible design covering architecture, data model, and medallion-based data pipeline, and (3) a reference implementation built on the Databricks platform. Together, these contributions offer application security teams a foundation for building a robust data platform independent of individual cybersecurity vendors, relieving them of risks usually associated with vendor lock-in.

Keywords

application security, software security, DevSecOps, security integration, data consolidation, medallion architecture, Databricks

Contents

Introduction	11
Motivation	11
Objective	11
Methodology	11
Structure	11
1 Analysis and Requirements	12
1.1 Application Inventory	13
1.1.1 Application Portfolio Management	13
1.1.2 Configuration Management Databases	13
1.1.3 Integration and Challenges	13
1.2 Software Development	13
1.2.1 Source Code Management	13
1.2.2 Continuous Integration and Delivery	13
1.2.3 Issue Tracking	13
1.3 Application Security	13
1.3.1 Static Application Security Testing	13
1.3.2 Software Composition Analysis	13
1.3.3 Secret Detection	13
1.3.4 Dynamic Testing and Penetration Testing	13
1.3.5 Container Image Scanning	13
1.3.6 Infrastructure as Code Security	13
1.3.7 Runtime Security Monitoring	13
1.4 Data Engineering	13
1.4.1 Data Platform Architecture	13
1.4.2 Data Integration Patterns	13
1.4.3 Domain Data Model	13
1.5 Related Work and Gap Analysis	13
1.5.1 Existing Approaches	13
1.5.2 Databricks Lakewatch	13
1.5.3 Comparative Analysis and Research Gap	13
2 Framework	14
2.1 Solution Architecture	15
2.1.1 Component Design	15
2.1.2 Medallion Architecture	15
2.1.3 Technology Stack	15
2.2 Data Model	15
2.2.1 Schema Patterns	15

2.2.2	Entity Model	15
2.2.3	Aggregation Model	15
2.3	Connector Framework	15
2.3.1	Connector Abstraction	15
2.3.2	Ingestion Patterns	15
2.3.3	Transformation Patterns	15
2.4	Analytics and Serving Layer	15
2.4.1	Aggregation Patterns	15
2.4.2	ML Workflows	15
2.4.3	Serving Patterns	15
2.5	Deployment and Engineering Practices	15
2.5.1	Deployment Strategy	15
2.5.2	Project Structure	15
2.5.3	Testing Strategy	15
3	Reference Implementation	16
3.1	Environment and Deployment	17
3.1.1	Workspace Setup	17
3.1.2	Silver Schema	17
3.1.3	Project Structure and CI/CD	17
3.2	Connectors	17
3.2.1	ServiceNow	17
3.2.2	GitHub	17
3.2.3	GitLab	17
3.2.4	SonarQube	17
3.2.5	Semgrep	17
3.2.6	Dependency-Track	17
3.2.7	TruffleHog	17
3.2.8	Vulnerability Enrichment	17
3.3	Analytics and Serving	17
3.3.1	Application-Repository Mapping	17
3.3.2	Application Risk Scoring	17
3.3.3	Remediation and Compliance Metrics	17
3.3.4	Vulnerability Trends	17
3.3.5	Risk Prediction Model	17
3.3.6	Serving Layer	17
3.4	Testing and Validation	17
	Conclusion	18
	Thesis Outcomes and Contributions	18
	Limitations	18
	Future Work	18
A	Generative AI Use Disclosure	20

A.1	Text Content	20
A.2	Diagrams and Figures	20
A.3	Source Code	20
A.4	Requirements Specification	20

List of Figures

List of Tables

List of source codes

Introduction

Motivation

Objective

Methodology

Structure

1. Analysis and Requirements

1.1 Application Inventory

1.1.1 Application Portfolio Management

1.1.2 Configuration Management Databases

1.1.3 Integration and Challenges

1.2 Software Development

1.2.1 Source Code Management

1.2.2 Continuous Integration and Delivery

1.2.3 Issue Tracking

1.3 Application Security

1.3.1 Static Application Security Testing

1.3.2 Software Composition Analysis

1.3.3 Secret Detection

1.3.4 Dynamic Testing and Penetration Testing

1.3.5 Container Image Scanning

1.3.6 Infrastructure as Code Security

1.3.7 Runtime Security Monitoring

1.4 Data Engineering

1.4.1 Data Platform Architecture

1.4.2 Data Integration Patterns

2. Framework

2.1 Solution Architecture

2.1.1 Component Design

2.1.2 Medallion Architecture

2.1.3 Technology Stack

2.2 Data Model

2.2.1 Schema Patterns

2.2.2 Entity Model

2.2.3 Aggregation Model

2.3 Connector Framework

2.3.1 Connector Abstraction

2.3.2 Ingestion Patterns

2.3.3 Transformation Patterns

2.4 Analytics and Serving Layer

2.4.1 Aggregation Patterns

2.4.2 ML Workflows

2.4.3 Serving Patterns

2.5 Deployment and Engineering Practices

2.5.1 Deployment Strategy

2.5.2 Project Structure

3. Reference Implementation

3.1 Environment and Deployment

3.1.1 Workspace Setup

3.1.2 Silver Schema

3.1.3 Project Structure and CI/CD

3.2 Connectors

3.2.1 ServiceNow

3.2.2 GitHub

3.2.3 GitLab

3.2.4 SonarQube

3.2.5 Semgrep

3.2.6 Dependency-Track

3.2.7 TruffleHog

3.2.8 Vulnerability Enrichment

3.3 Analytics and Serving

3.3.1 Application-Repository Mapping

3.3.2 Application Risk Scoring

3.3.3 Remediation and Compliance Metrics

3.3.4 Vulnerability Trends

3.3.5 Risk Prediction Model

Conclusion

Thesis Outcomes and Contributions

Limitations

Future Work

Appendices

A. Generative AI Use Disclosure

A.1 Text Content

A.2 Diagrams and Figures

A.3 Source Code

A.4 Requirements Specification